

공개 배포판

# ODRE PQC v0.2.9

Public Technical Whitepaper Rev.2

한국어판

2026년 9월 2일

---

# 목차

1. 요약
2. 제품 목적과 아키텍처
3. 암호 프로파일과 보안 계약
4. 위협 모델과 신뢰 경계
5. 검증 및 감사 근거
6. 교차 플랫폼 결과
7. Commercial Layer 분리
8. 배포 및 공개 범위
9. 결론

## Document identity

|                           |                                                                  |
|---------------------------|------------------------------------------------------------------|
| Product                   | ODRE PQC                                                         |
| Version                   | 0.2.9                                                            |
| Artifact                  | odre_pqc-0.2.9-py3-none-any.whl                                  |
| Wheel SHA-256             | A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697 |
| Evidence manifest SHA-256 | 4AF2C88FDEA0CB1FB030E4AB6D5B41394CC52397664364233482E3EC14945F3B |
| Cryptographic runtime     | OpenSSL 3.5.8 / ML-KEM-768 / ML-DSA-65                           |
| Verified platforms        | Windows Server 2022 AMD64; Ubuntu 24.04.4 LTS AMD64              |
| Core audit verdict        | ODRE_PQC_v0.2.9_FULL_DEVSEC_AUDIT_PASS                           |

---

## 요약

ODRE PQC는 보호 대상 FastAPI 경로에 설치되는 애플리케이션 내장형 포스트양자 보안 경계다. 작은 통합 표면 뒤에서 암호 Runtime 관리, 인증 세션 수립, 엄격한 Sequence, Replay 저항성, 보호 요청·응답 의미론, Native Artifact 신뢰, Lifecycle 제어와 Fail-Closed 집행을 결합한다.

v0.2.9는 본 문서의 SHA-256으로 식별되는 봉인된 교차 플랫폼 Artifact다. 정확히 동일한 Wheel이 Windows Server 2022 AMD64와 Ubuntu 24.04.4 LTS AMD64에서 새로 수행한 전체 개발 보안감사를 통과했다. 실행 범위 내 확인된 Critical·High·Medium 제품 결함은 남아 있지 않았다.

이 문서는 절대적 보안이 아니라 근거를 보고한다. PASS는 명시된 Artifact, Platform, 구성, 위협 모델과 실행된 시험 범위에만 적용된다. Production 배포는 별도의 운영자 통제 결정이다.

---

# 제품 목적과 아키텍처

ODRE PQC는 선택된 애플리케이션 경로를 보호한다. TLS, Identity, Authorization, Secure Coding, Host Hardening, Patch, Backup, Monitoring을 대체하지 않는다. 보호된 비즈니스 Handler는 PQC 경계가 요청을 승인한 뒤에만 실행된다.

공개 통합 모델은 의도적으로 작다. 초기화, 진단, 검증, install(app) 호출, 서버 시작, 인증된 Status 확인으로 구성된다. Wire Contract는 odre-pqc/3으로 버전 관리되며 OS 차이는 Adapter와 Platform별 Native Runtime Bundle 내부에 머문다.

```
통합 흐름: odre-pqc init -> doctor -> verify -> from odre_pqc import install; install(app) -> server start -> odre-pqc status
```

---

# 암호 프로파일과 보안 계약

감사 Runtime은 OpenSSL 3.5.8(OpenSSL\_version\_num 0x30500080)로 식별됐다. 실제 ML-KEM-768, ML-DSA-65 Self-test와 Hybrid Handshake가 두 대상 OS에서 통과했다.

보호 경로에서 Classical-only로 조용히 전환하지 않는다. Provider, Key Material, Session, Replay State, Native Trust 또는 Runtime Health가 계약을 충족하지 못하면 Business Logic 실행 전에 보호 경로를 차단한다.

Handler가 관찰하는 요청 의미론은 인증된 내부 의미론과 일치한다. 보호 응답의 Status, 순서가 있는 Header, Cookie와 Body는 보호 Frame 내부에 유지된다. Replay, Rollback, Gap, Mismatch, Cross-route와 Cross-session 모호성은 Fail-Closed로 거부된다.

---

# 위협 모델과 신뢰 경계

감사는 Network Tamper, Replay와 동시성, 비정상·과대 입력, 의미론 혼동, 응답 Metadata 노출, Crash/Restart State, Local Filesystem 교체, Symlink/Reparse 조작, Dependency·Provider Injection과 Lifecycle Race를 시험했다.

OS, CPU, Python Runtime과 승인된 관리자가 완전히 장악되지 않았음을 가정한다. 악성 Kernel, 무제한 관리자 권한, Physical Extraction, 승인 이후의 Application Logic 침해, 시험 밖 DoS, 미래 암호해독 돌파에 대한 보호를 주장하지 않는다.

# 검증 및 감사 근거

봉인 Wheel의 새 복사본을 Hash Lock 상태로 설치했고 시작·종료 Hash가 일치했다. 과거 보고서를 PASS 근거로 재사용하지 않았고 감사 중 제품 Byte를 변경하지 않았다.

정적 검토는 Python 38개 파일·7,160줄, Package Metadata, RECORD, Platform Support와 양쪽 Native Manifest·Archive를 포함했다. Wheel RECORD 45/45가 통과했다. 당시 19개 Dependency에 대한 새 Advisory 조회는 오류 0, 반환된 취약점 Record 0이었다.

| Metric                              | Windows   | Ubuntu    |
|-------------------------------------|-----------|-----------|
| Platform verdict                    | PASS      | PASS      |
| Replay-race requests                | 1,280     | 2,880     |
| Double handler execution            | 0         | 0         |
| Native load attempts                | 3,000     | -         |
| Atomic replacements observed        | 1,062     | -         |
| Junction create/remove cycles       | 3,000     | -         |
| Late-promotion parent swaps         | -         | 600 / 600 |
| Untrusted load / object misbinding  | 0         | 0         |
| Unresolved Critical / High / Medium | 0 / 0 / 0 | 0 / 0 / 0 |

---

## 교차 플랫폼 결과

Windows 시험은 Offline 설치, 초기화, 2차 초기화 방지, Doctor, Verify, 인증 Status, Session 전환, Replay Race, 의미론 Binding, ACL Trust, Shutdown Lifetime, Tamper 공격, Crash Recovery와 Native Load Stress를 포함했다.

Ubuntu 시험은 초기화, Negative Diagnostics, 실제 PQC, Replay Race, Admission Fuzz, 비정상·과대 입력, HTTP Smuggling 형태, 응답 비밀성, WebSocket Fail-Closed, Native Object Trust, 동시 초기화, Worker Collision과 정상·강제 Restart를 포함했다.



---

# Commercial Layer 분리

License, Payment, Download, Trial, Monitoring Service는 Commercial Control Plane이며 봉인된 v0.2.9 암호 Core가 아니다. Commercial Server Code는 격리 시험 102/102, 선택된 JigeumON 회귀 시험은 60/60을 통과했다. 격리 Migration Upgrade-Downgrade-Upgrade도 통과했다.

이는 Production 배포 주장이 아니다. PostgreSQL Acceptance, Live PayPal, SMTP, Production Secret, Trusted Proxy, 배포된 Customer Helper와 End-to-end Client Entitlement Enforcement는 해당 보고서에서 완료되지 않았다. 판정은 Code·Isolated Tests PASS, Production NOT READY다.

---

# 배포 및 공개 범위

공식 검증 환경은 Windows Server 2022 AMD64·CPython 3.12.10과 Ubuntu 24.04.4 LTS AMD64·CPython 3.12.3이다. 그 밖의 Linux, Ubuntu 22.04, Debian 12와 ARM64는 이 근거로 검증됐다고 표시하지 않는다.

이 공개판에는 Private Key, Credential, 제품 Source, Wheel Byte, Native Binary, Test Harness, Customer Data를 공개하지 않는다. 내부 보고서는 비공개로 유지한다. 독립 Source Report가 발견되지 않은 약 1.794억 Fuzz 계보 수치는 의도적으로 주장하지 않는다.

---

## 결론

ODRE PQC v0.2.9는 엄격한 Fail-Closed 계약, 실제 포스트양자 알고리즘과 봉인된 교차 플랫폼 Artifact Identity를 작은 통합 표면으로 제공한다. 확보된 근거는 정의된 범위에서 명시된 개발 보안감사 결과를 뒷받침한다.

보안은 지속 과정이다. 운영자는 Artifact Identity를 보존하고 지원 배포 지침을 따르며 Host와 Application을 유지관리하고, 향후 변경을 새로운 검증 의무로 다뤄야 한다.

공개 기술백서 Rev.2 - Core 주장과 Commercial 주장을 명시적으로 분리함.